

Governance in Practice

WHY THIS MODULE MATTERS

Policies mean nothing without effective governance behind them. This module builds your capability to design, evaluate and strengthen the structures that turn good intentions into consistent, accountable practice.

5.1 What Governance Actually Does

Governance is the set of structures that make an organisation's ethical commitments consistent, repeatable and auditable, rather than dependent on the judgment of whichever individual happens to be involved in a given project. Effective governance does not slow innovation for its own sake; it exists to catch the compounding, reasonable-seeming decisions described in Module 3 before they reach production.

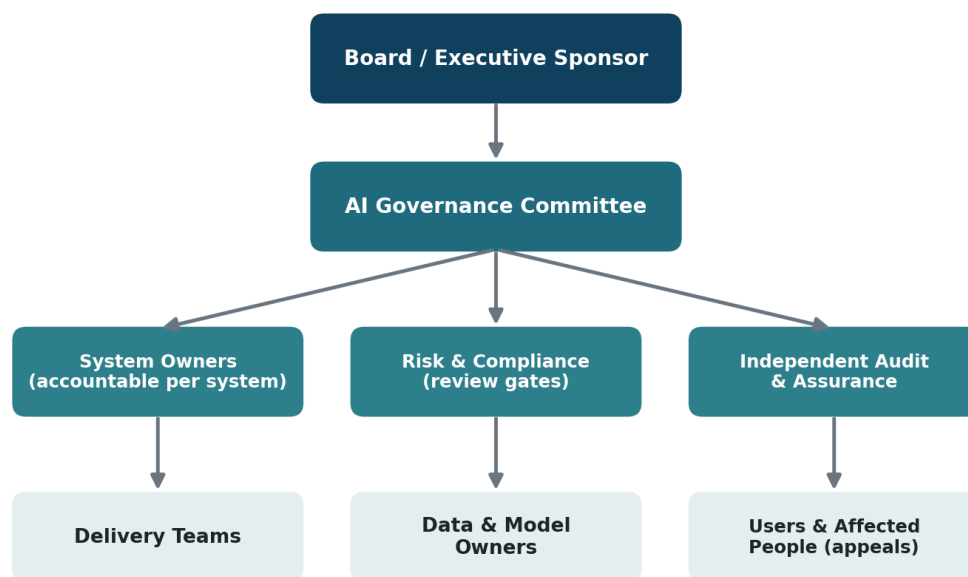


Figure 5.1 — A typical AI governance structure, distributing accountability across roles rather than concentrating it in one.

CASE STUDY — THE DUTCH CHILDCARE BENEFITS SCANDAL

From around 2013, the Dutch tax authority used a self-learning algorithm to flag applicants for childcare benefit fraud investigations. The system treated having a second nationality as a risk factor, and disproportionately targeted lower-income families and those with a migration background; an investigation later found some local rollouts even factored in applicants' clothing and Dutch-language fluency.

Over 26,000 families were wrongly accused of fraud, often on the basis of minor administrative errors or no wrongdoing at all, and ordered to repay tens of thousands of euros in benefits, sometimes retroactively over several years. Families lost homes, savings and, in some documented cases, custody of children as a result of the resulting financial collapse.

Crucially, the system was described afterwards as a self-learning “black box”: no single official could fully explain why a specific family had been flagged, no one had signed off on treating dual nationality as a risk signal, and there was no accessible route for a wrongly flagged family to have a human meaningfully review their case before enforcement action began. In January 2021, the entire Dutch cabinet resigned over the scandal — one of the most significant political consequences of an ungoverned algorithm anywhere in the world.

5.2 The NIST AI Risk Management Framework

Rather than inventing governance from scratch, most mature organisations now build on a small number of published frameworks. The most widely referenced is the US National Institute of Standards and Technology's AI Risk Management Framework (AI RMF), published in January 2023. It is voluntary and organises AI governance work into four interlocking functions.

- **Govern** — the cross-cutting foundation: policies, named accountability, and a culture where raising a concern is treated as diligence. This is precisely what was absent in the Dutch case — no one owned the decision to treat nationality as a risk factor, and no policy required it to be justified.
- **Map** — understanding the specific context a system operates in: who it affects, what could go wrong, and what “high risk” means for this particular use case.
- **Measure** — testing the system against defined metrics — accuracy, fairness across groups, robustness — using both quantitative testing and qualitative review.
- **Manage** — turning what Measure finds into action: prioritising fixes, deciding whether a system should be paused, and communicating with people affected by its decisions.

The four functions are not a one-off checklist to complete before launch; NIST describes them as a continuous loop, where what Manage learns from a live system feeds back into Govern to update policy for the next one. Applied to the Dutch case: Govern should have required documented justification for any variable used as a fraud-risk signal; Map should have flagged that treating nationality as a proxy risked discriminatory impact; Measure should have tested false-positive rates by nationality before deployment; and Manage should have included a genuine human review route once families began disputing their treatment.

5.3 Core Governance Structures

- **AI inventory** — a maintained record of every AI system in use, including its purpose, owner, data sources and risk level. Organisations cannot govern systems they do not know exist.
- **Risk tiering** — a method for classifying systems by potential impact, so that low-stakes systems move quickly while high-stakes systems (credit, hiring, healthcare, safety, welfare fraud detection) receive proportionally deeper review.
- **Review gates** — defined checkpoints, tied to the development lifecycle, where a system must meet specific criteria before advancing to the next stage.
- **Named accountability** — a specific role or committee formally responsible for a system's outcomes, distinct from the engineering team that built it.
- **Monitoring and audit** — ongoing measurement of a deployed system's performance and outcomes, not only a pre-launch assessment.
- **Incident and appeals process** — a defined channel through which affected people can contest a decision and the organisation can investigate and, where warranted, correct it.

5.4 Risk Tiering in Practice

A common governance failure is applying the same heavyweight review to every system regardless of risk, which tends to produce two bad outcomes: high-risk systems get review effort that is still insufficient for their stakes, while low-risk systems accumulate friction that erodes support for governance altogether. Risk-tiered governance calibrates the depth of review to the potential consequences of the system.

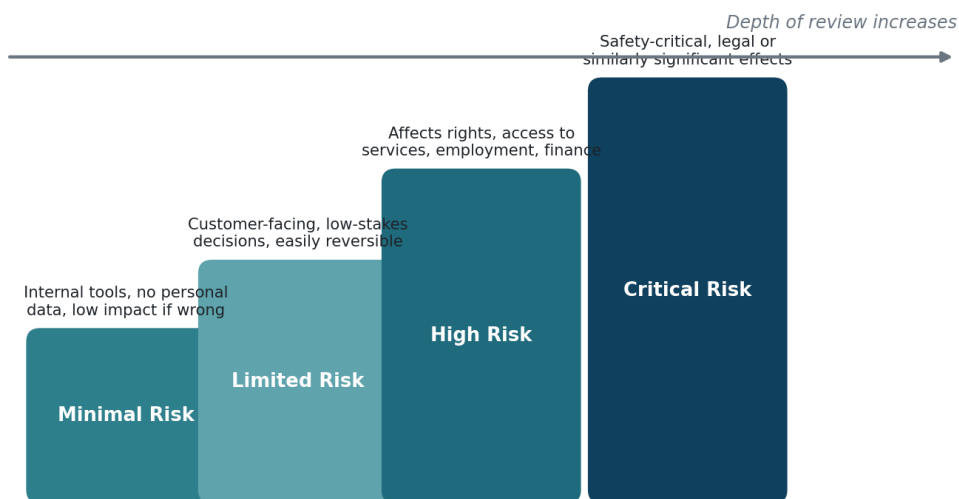


Figure 5.2 — A four-tier risk ladder; review depth increases with potential impact on people.

TRY THIS — YOU ARE THE GOVERNANCE COMMITTEE CHAIR

Scenario: two systems reach your committee on the same day. System A is an internal tool that drafts first replies to routine customer emails, which a human always edits before sending. System B is a new model that automatically approves or declines small business loan applications under £5,000, with no human review for approvals. A colleague argues both should get the same standard review, “to be fair.” Do you agree? (Model answer: no. Treating both identically wastes review capacity on System A, which is low-risk with a human already in the loop, while under-reviewing System B, which makes unsupervised financial decisions affecting real people — exactly the high-risk tier from Figure 5.2. “Fairness” in governance means proportionality to impact, not identical process regardless of stakes.)

TRY THIS — APPLY GOVERN-MAP-MEASURE-MANAGE

Take the Ofqual grading algorithm from Module 3. For each of the four NIST functions (Govern, Map, Measure, Manage), write one sentence describing what was missing in the actual 2020 rollout. (A model answer: Govern — no documented sign-off on using school history as a standardisation input; Map — the impact on small versus large schools was known internally but not treated as a governance risk; Measure — the algorithm was never tested against real teacher rankings before use; Manage — no working appeals route existed when results were published.)

UK IN FOCUS

UK regulators increasingly expect organisations to be able to demonstrate governance, not merely assert it. The ICO's accountability framework, the Bank of England and Prudential Regulation Authority's expectations for model risk management in financial services, and sector-specific guidance from bodies such as the MHRA for AI in medical devices all point in the same direction: documented ownership, documented testing, and documented review — the same four NIST functions applied through a UK regulatory lens.

5.5 Governance for Facilities, Security and Contracted Staff

Governance frameworks are frequently designed with in-house engineering and product teams in mind, and then quietly stop at the door of the plant room or the security gatehouse. In a data centre environment, this is a significant gap: facilities engineers, security officers and network operations technicians routinely have physical or system access that is at least as consequential as a software engineer's, and a large proportion of this workforce is employed through staffing and recruitment agencies rather than directly.

- **Vetting and screening** — UK data centre operators typically require security screening aligned to BS 7858 (screening of individuals working in a secure environment) for any contractor or agency worker with unescorted site access; recruitment partners should be able to evidence this as standard, not on request.
- **Induction into governance, not just safety** — site inductions routinely cover fire, electrical and manual-handling safety; they less often cover the AI governance structures in this module, even where agency staff will interact with AI-enabled building or access systems daily.

- **Extending named accountability to vendors** — where a building-management or access control system is run by a third-party vendor, the AI Governance Committee's oversight should extend contractually to that vendor, not stop at the client's own payroll boundary.
- **Consistent escalation regardless of employer** — an agency-employed security officer should have exactly the same route to escalate a concern about a system as a permanent employee; two-tier escalation paths are a common, avoidable governance gap.

5.6 Assessing Your Own Governance Maturity

Organisations rarely move from no governance to full governance in one step. It helps to locate where an organisation actually sits today, honestly, before setting out to improve it — both the Dutch tax authority and Ofqual would likely have assessed as “Ad Hoc” or “Developing” against the model below, despite each having some technical process in place.

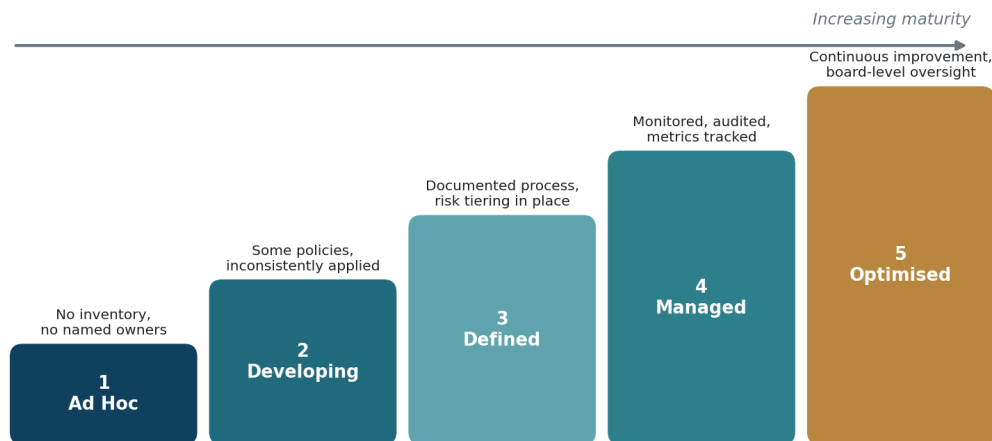


Figure 5.3 — A five-level AI governance maturity model.

5.7 AI Assurance: Demonstrating Governance, Not Just Having It

A maturity self-assessment is useful, but it is still self-reported. Increasingly, boards, regulators and clients are not asking “do you have AI governance?” — they are asking “how do you demonstrate it, to someone who doesn't take your word for it?” That is the role of assurance: independent or semi-independent verification that documented controls are actually operating as described, not simply written down.

- **Internal audit** — a function independent of the team that built or operates a system, testing whether its stated governance controls are followed in practice.
- **Independent or third-party assurance** — an external body reviewing evidence and issuing an opinion, similar to a financial audit; ISO/IEC 42001 certification (Module 8) is one increasingly recognised route to this.

- **Model validation** — a technical check, separate from the team that built a model, that its performance claims and fairness testing hold up under independent scrutiny.
- **Assurance statements** — a short, board-facing summary confirming what was checked, by whom, and what was found — the artefact that actually answers “how do we know?”

Assurance does not replace the governance structures earlier in this module; it verifies them. An AI inventory with no assurance behind it is a claim. An AI inventory that internal audit has sampled and confirmed against actual live systems is evidence.

5.8 Risk Heat Maps and Role Clarity

Two further artefacts make governance visible and usable in practice, rather than living only in policy documents. A risk heat map plots likelihood against impact so that scarce review time is spent on the systems in the top-right corner, not spread evenly across everything. A role matrix makes explicit who is Responsible for doing the work, Accountable for the outcome, Consulted before a decision, and Informed after it — the RACI model — for each governance activity, closing exactly the kind of ownership gap that let the Dutch and Ofqual algorithms run unchecked.

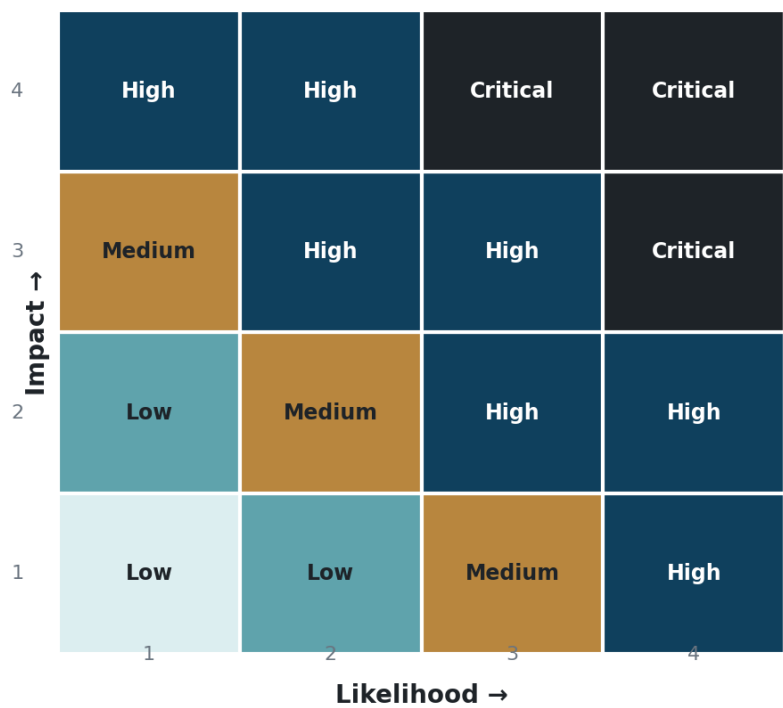


Figure 5.4 — A risk heat map: likelihood versus impact, used to prioritise review effort.

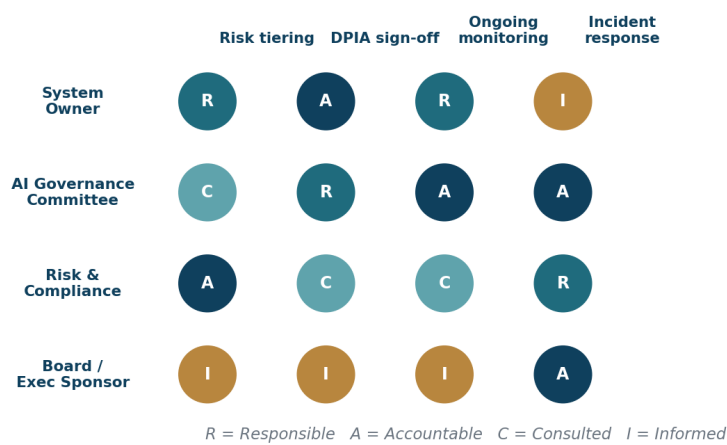


Figure 5.5 — A RACI role matrix clarifying who is Responsible, Accountable, Consulted and Informed for each governance activity.

Governance Artefact: A One-Page AI Risk Assessment Template

The table below is a minimal, reusable template you can adapt directly. Completing one page like this for a real system in your own organisation is more valuable than reading any amount of theory about risk assessment.

Field	What to record
System name & purpose	One sentence: what does it do, and for whom?
Risk tier	Minimal / Limited / High / Critical (Module 5.4)
Named owner	One person, by name and role — not a team
Key risks identified	Technical, social, organisational (Module 3)
Fairness definition applied	Demographic parity / error-rate balance / calibration (Module 2)
Lawful basis (if personal data)	See Module 6
DPIA required?	Yes / No, with reasoning
Monitoring metric	What would reveal a problem, and how often is it checked?
Escalation route	Who does an affected person or member of staff contact?
Review date	When this assessment is next revisited

KEY TAKEAWAYS

- Governance turns ethical commitments into consistent, repeatable and auditable organisational practice — the Dutch childcare scandal shows what happens without it.
- The NIST AI Risk Management Framework's four functions — Govern, Map, Measure, Manage — give a reusable structure for diagnosing exactly where a governance failure occurred.
- Core structures include an AI inventory, risk tiering, review gates, named accountability, ongoing monitoring and an appeals process.
- Assurance — internal audit, independent review, model validation — is what turns a governance claim into evidence a board or client can actually rely on.
- A maturity model, a risk heat map and a RACI role matrix turn governance from a policy document into something a team can actually use day to day.
- Governance frameworks must extend to facilities, security and agency-employed staff, not only in-house technical teams — including vetting, induction and escalation routes.

FURTHER READING

- NIST — AI Risk Management Framework 1.0 and Playbook, nist.gov
- Dutch Data Protection Authority (Autoriteit Persoonsgegevens) — findings on the SyRI childcare benefits system
- ICO — Accountability Framework, ico.org.uk
- Chartered Institute of Internal Auditors — guidance on AI assurance and internal audit

MODULE 5 CHECK-IN QUIZ

Five questions to confirm your understanding before moving on. Answers are provided in the Answer Key at the end of the course.

1. What is the primary purpose of an AI inventory in a governance programme?

- A. To rank employees by technical skill
- B. To maintain a record of every AI system in use, including its purpose, owner and risk level
- C. To replace the need for a DPIA
- D. To store training data permanently

2. Why does Module 5 recommend risk-tiered governance rather than a single uniform review process?

- A. Uniform review is always faster
- B. Applying the same heavyweight review to every system under- and over-resources risk at the same time
- C. Regulators require identical review for all systems
- D. Risk tiering removes the need for named accountability

3. Which role is typically accountable for a specific AI system's day-to-day performance and outcomes?

- A. The system owner
- B. Any available engineer
- C. The end customer
- D. No one; accountability is intentionally diffused

4. What do UK regulators such as the ICO and the PRA increasingly expect of organisations regarding AI governance?

- A. A verbal assurance that controls exist
- B. Demonstrable, documented evidence of ownership, testing and review
- C. No documentation, only outcomes
- D. Reliance solely on vendor certifications

5. In the fraud-detection example, why does the model receive a high-risk classification?

- A. Because it is expensive to run
- B. Because it can freeze a customer's account, a significant impact on the individual
- C. Because it uses more data than other systems
- D. Because it was built in-house rather than bought